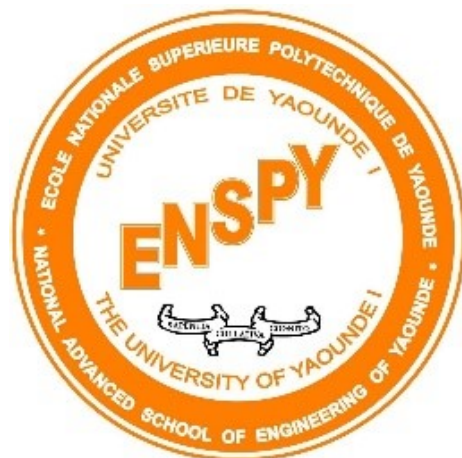




THEORIES ET PRATIQUES DE L'INVESTIGATION NUMERIQUE.

Enseignant: M.MINKA THIERRY.
Par l'étudiante: CHEUTCHEULONGA HILARY PAULA
Filière CIN 4

Année Académique: 2025-2026.

RESUME DU COURS D'INVESTIGATION NUMERIQUE

Ce cours aborde l'investigation numérique en commençant par les fondements éthiques et déontologiques de l'investigation numérique à travers des piliers éthiques, des engagements pour l'investigateur, et des commandements pour l'investigateur que nous allons dérouler plus tard. Le document est subdivisé en plusieurs parties, la première partie retrace l'histoire et l'évolution de l'investigation numérique ainsi que les fondements mathématiques et théoriques sur lesquels il est basé et les premières affaires aux défis du big data et du quantique. Dans la deuxième partie, les cadres théoriques incluant le principe de loyauté et divers modèles d'investigation, les différentes évolutions scientifiques qui ont fait progresser l'investigation numérique. Une partie est dédiée à l'impact de l'informatique quantique, introduisant le trilemme CRO (Confidentialité, Fiabilité, Opposabilité) ainsi que le protocole ZK-NR (Zero-Knowledge Non-Repudiation). Les législations mondiales et régionales sont examinées y compris le droit camerounais en détaillant les outils avancés, les pratiques opérationnelles, les techniques anti-forensiques et les contremesures. Avant le début du cours proprement dit, nous avons eu droit à un typique exemple de ce à quoi un individu doit connaître et faire avant d'accéder à la discipline technique de cette discipline. Ses prérequis sont : -L'engagement qui est un contrat moral entre l'apprenant et la communauté des investigateurs numériques. Nous avons les engagements fondamentaux qui dirigent l'investigateur sur le bon l'usage de ses connaissances en vers la société, ensuite viennent les engagements techniques qui dirigent l'investigateur sur les techniques simples mais essentiel nécessaire lors de l'application de ses connaissances. -Les quatre piliers de la pratique éthique : 1. Pilier Principes Intégrité Vérité des conclusions, transparence des méthodes, reconnaissance des limites. 2. Proportionnalité Adéquation des moyens aux fins, minimisation de l'intrusion, respect de la vie privée. 3. Responsabilité Acceptation des conséquences de ses actions, devoir de vigilance, obligation de formation. 4. Service Mise des compétences au service de la justice, de la légalité et de la protection des droits. -Les dix commandements de l'investigateur : 1. Tu ne causeras pas de dommage aux systèmes que tu investigues. 2. Tu respecteras la vie privée et la dignité des personnes. 3. Tu maintiendras la chaîne de traçage sans faille. 4. Tu documenteras intégralement tes processus et décisions. 5. Tu reconnaitras les limites de tes compétences et connaissances. 6. Tu résisteras aux pressions contraires à l'éthique. 7. Tu protégeras les données sensibles dont tu as la garde. 8. Tu témoigneras avec honnêteté et objectivité. 9. Tu con-

tribueras au développement de la discipline.¹⁰ Tu honoreras la confiance que la société place en toi. Par la suite nous avons aussi les engagements par domaines, sans oublier les sanctions et conséquences sévères en cas de non-respect de ces engagements tels que : La perte de crédibilité professionnelle, l'exclusion des communautés d'investigateurs, des conséquences juridiques et disciplinaires, la nullité des preuves obtenues illicitement.

Dans la première partie du cours qui parle des fondements, historique et évolution de l'investigation numérique. Avec des citations à l'appui à chaque nouveau chapitre nous avons commencé avec les fondements mathématiques et théoriques qui sont au sein de l'investigation numérique, comme le théorie de l'information de Shannon où la mathématique de l'investigation puise ses fondements, la théorie des graphes et relations, la théorie du chaos et sensibilité aux conditions initiales qui est principalement pour les systèmes complexes de l'investigation où une minuscule altération peut avoir des conséquences considérables. La venue de la révolution quantique transforme et bouleverse les fondements classiques de l'investigation numérique avec des notions comme la superposition, la non-localité, et l'incertitude. Elle présente le paradoxe de l'authenticité invisible, qui illustre la tension entre vérifiabilité et confidentialité des preuves numériques, et propose les protocoles ZK-NR comme solution. Le deuxième chapitre de cette partie retrace l'évolution de l'investigation numérique depuis les premiers crimes informatiques des années 1970 jusqu'à l'ère post-quantique actuelle. Il met en lumière des affaires marquantes comme celles des "414s", Enron (2001), Gary McKinnon (2002), Silk Road (2013), Panama papers (2016), ou encore SolarWinds (2020), qui ont chacune contribué à l'émergence de nouvelles techniques d'analyse, de préservation de preuves et de standardisation. L'histoire est marquée par des innovations majeures telles que la blockchain forensique, l'intelligence artificielle, et l'analyse comportementale, tout en soulignant l'importance croissante des métadonnées et des protocoles d'attribution. Au troisième chapitre, parle des affaires qui ont marqué l'évolution de l'investigation numérique comme : L'affaire BTK Killer (2005) qui démontre le rôle crucial des métadonnées dans l'identification d'un criminel, l'affaire Stuxnet (2010) qui révèle l'émergence de la cyberarme avec des techniques avancées de reverse engineering et d'analyse comportementale, enfin, l'affaire WannaCry (2017) qui illustre l'impact mondial d'une attaque par ransomware et l'importance de l'analyse en temps réel, notamment grâce à la découverte d'un mécanisme d'arrêt (Domain generation algorithm) par Marcus Hutchins. Ces cas ont enrichi les méthodes forensiques et renforcé la vigilance face aux menaces numériques.

A la deuxième partie du cours, les théories de l'investigation numérique telles que le principe de Locard adapté au numérique qui stipule que "toute action laisse une trace", et il se subdivise en deux catégories de traces : primaires incluent les logs système, les registres et les fichiers temporaires, qui enregistrent des événements. Et les traces secondaires qui sont des métadonnées

(comme les EXIF et timestamps des fichiers), et les empreintes comportementales. Autres théories sont les modèles d'enquête reconnus (DFRWS, Casey, ISO/IEC 27037), et des outils mathématiques comme l'entropie de Shannon, la distance de Hamming et la théorie des graphes sont présentés et expliqués. Ces principes et modèles ont impacté l'évolution scientifique continue qui a vu des étapes importantes telles que la première saisie de données informatiques en 1979 et le développement des outils forensiques comme EnCase et Sleuth Kit, ainsi que l'émergence de la Cloud Forensics et de la Memory Forensics dans les années récentes. Dans la suite du cours, les cadres normatifs mondiaux qui régissent les pratiques de collecte, de préservation, d'analyse et d'interprétation des preuves numériques sont abordés. L'idée centrale est que la loi doit offrir un cadre régulateur sans freiner l'innovation, protéger sans étouffer et réguler sans paralyser. Plusieurs normes clés sont abordées telles que l'ISO/IEC 27037:2012 (qui fournit des lignes directrices pour l'identification et la collecte des preuves numériques en se basant sur des principes comme la pertinence, la fiabilité, la suffisance et la documentation complète.), l'ISO/IEC 27041:2015 pour l'assurance de la méthode d'investigation, l'ISO/IEC 27042:2015 pour l'analyse et l'interprétation des preuves, l'ISO/IEC 27043:2015 qui guide les étapes de l'investigation, La norme NIST SP 800-86 décrit les étapes de l'intégration des techniques forensiques dans la réponse aux incidents, tandis que les lignes directrices RFC 3227 traitent de la collecte des preuves et de l'archivage. Les meilleures pratiques mondiales de l'investigation numérique sont décrits avec des détails sur les phases d'implémentation de ses différents approches, nous avons, en premier la méthodologie du SANS Institute, dans le cours FOR508 "Advanced Incident Réponse and Threat Hunting" est étudié, il repose sur une approche en six phases pour la gestion des incidents : La première phase, Préparation, inclut la mise en place d'un plan de réponse aux incidents, la validation des outils et la formation de l'équipe. Ensuite, la phase Identification se concentre sur le développement des indicateurs de compromission (IoC), l'intégration du renseignement sur les menaces et la détection des anomalies. La phase Confinement cherche à isoler les menaces à court terme et à planifier l'éradication à long terme tout en préservant les preuves. L'éradication suit, avec la suppression des malwares, le patching des vulnérabilités et le renforcement des systèmes. La phase Récupération permet la restauration des systèmes, l'amélioration de la surveillance et la validation des tests. Enfin, la phase Leçons apprises permet une révision post-incident, l'amélioration des processus et la mise à jour de la documentation. Ensuite le processus du CERT/CC, basé sur le cadre de Carnegie Mellon, se divise en quatre étapes : Détection, Triage, Réponse et Post-Incident, où la surveillance, l'analyse, la remédiation et l'amélioration continue sont essentielles. Le CERT recommande divers outils, tels qu'AXIOM pour la criminalistique, X-Ways et FTK pour l'analyse de données, ainsi que des outils spécifiques à la criminalistique mobile comme Cellebrite et Oxygen. Puis l'approche européenne, proposée par l'ENISA, repose sur un cadre structuré en trois phases : Pré-investigation, Investigation et Post-investigation. La pré-investigation met l'accent sur l'autorisation légale et l'évaluation des risques, tandis que l'investigation se concentre sur l'acquisition

de preuves, l'exécution de l'analyse et la validation des hypothèses. La phase post-investigation inclut la génération de rapports, la préparation pour les tribunaux et le transfert des connaissances. Et enfin le modèle DFRC-K, utilisé en Asie, met l'accent sur la criminalistique mobile, en raison de la forte pénétration des smartphones, et intègre des systèmes d'identification nationaux ainsi que des applications de messagerie locales telles que KakaoTalk et LINE. Pour accompagner ces méthodologies, nous avons des outils et techniques avancés tels que l'arsenal de l'investigateur moderne comprend des outils pour l'acquisition forensique et l'analyse de mémoire, les techniques d'anti-forensique qui comprennent des techniques légales de contournement de chiffrement tels que cold boot attack, evil maid attack et DMA attack, enfin les techniques d'intelligence artificielle en investigation comme le machine learning pour la classification des malwares, le deep learning pour analyse comportementale.

Dans une partie du cours qui parle de l'ère du post-quantique ; ont décrit l'impact crucial de l'informatique quantique sur l'investigation numérique en commençant par les menaces quantiques telles que l'algorithme de Shor qui factoriser rapidement de grands nombres, menaçant ainsi les systèmes cryptographiques actuels comme RSA, ECC et DSA/ECDSA, Avec une obsolescence prévue vers 2040 selon le NIST. L'algorithme de Grover qui accélère la recherche et réduit la sécurité des clés symétriques (ex. AES-128 à une sécurité équivalente 64 bits). En investigation numérique, les algorithmes sélectionnés par le NIST avec signatures (CRYSTALS-Dilithium, FALCON, SPHINCS+) et encapsulation de clés (CRYSTALS-Kyber, BIKE, HQC), peuvent être utilisés pour signer les preuves de manière résistante au futur quantique. Le protocole Zero-Knowledge Non-Répudiation (ZK-NR) est une solution cryptographique avancée combinant Merkle commitments, preuves STARK post-quantiques, signatures distribuées Threshold BLS et authentification Dilithium pour garantir une non-répudiation légale tout en préservant la confidentialité. Le protocole suit plusieurs étapes : engagement via Merkle, génération de preuve zero-knowledge, signatures à seuils, et authentification post-quantique, assurant ainsi un équilibre optimal entre confidentialité, fiabilité et opposabilité (Trilemme CRO). En investigation numérique, ZK-NR permet de créer une chaîne de possession (Chain of Custody) résistante aux attaques quantiques, assurant un transfert de preuves inviolable et vérifiable. Les avantages de ce protocole sont une non-répudiation absolue et un respect strict de la vie privée, tandis que les défis concernent la complexité technique, l'interopérabilité et les coûts de performance. Ce protocole illustre également comment la conception sécurisée repose sur le modèle Zéro Trust, le minimalisme et la défense en profondeur, indispensables face aux menaces actuelles et futures, notamment quantiques. Pour ces protocoles utilisés, il est nécessaire d'avoir une méthodologie d'analyse formelle pour les protocoles, ceci est essentielle pour garantir la sécurité réelle des systèmes cryptographiques. L'analyse débute par la modélisation des menaces, notamment avec le modèle Dolev-Yao qui suppose un attaquant capable de contrôler le réseau sans toutefois casser les primitives cryptographiques

par force brute. Les outil d'analyse comme Tamarin permet d'automatiser la vérification des propriétés dans un cadre de logique temporelle, même si des limites pratiques et des nécessités de preuves manuelles subsistent. La méthodologie d'audit se compose de cinq étapes : compréhension du protocole et ses objectifs, modélisation du modèle de menace et des propriétés, analyse manuelle des vulnérabilités courantes, analyse automatique avec des outils formels, et enfin tests d'implémentation (fuzzing, analyse statique et dynamique). L'analyse approfondie du protocole ZK-NR illustre cette démarche, soulignant ses forces (modularité, défense en profondeur, confidentialité) ainsi que ses vulnérabilités (gestion des clés, complexité, dépendance à la couche BLS vulnérable au quantique). L'étude de la signature BLS révèle sa robustesse classique mais sa faiblesse face à l'algorithme de Shor quantique, justifiant son couplage avec Dilithium pour assurer sécurité post-quantique et équilibre du Trilemme CRO (confidentialité, fiabilité, opposabilité).

On ne peut parler de pratique ou de méthodologie sans introduire les réglementations qui doivent organiser les pratiques pour éviter un désordre lors de la mise en place de ses différents pratiques. Ainsi une le législation mondiale et régionale en matière de cybercriminalité et d'investigation numérique était nécessaire pour insister sur l'impérative coopération internationale face à un crime sans frontières. Aux États-Unis, les règles fédérales de preuve (FRE) imposent notamment la validation de l'authenticité des preuves (avec usage minimum de SHA-256) et une documentation rigoureuse de la chaîne de possession, appuyées par des lois comme le Stored Communications Act (SCA) pour la protection des communications stockées, et le Computer Fraud and Abuse Act (CFAA) pour définir les infractions. En Europe, le règlement eIDAS structure les signatures électroniques sur trois niveaux (simple, avancé, qualifié), tandis que le RGPD crée des tensions entre protection des données et besoins d'investigation, assorties d'exceptions pour la sécurité nationale et la justice. La Convention de Budapest favorise l'harmonisation législative et facilite l'entraide Judiciaire internationale avec un protocole récent d'accès transfrontalier urgent. En Afrique, la Convention de Malabo et plusieurs cadres régionaux (CEDEAO, SADC, EAC) établissent des normes pour la cybersécurité, la cybercriminalité et la protection des données, quoique la ratification reste faible. Au Cameroun, plusieurs lois encadrent la cybersécurité, la conservation des données et la protection des données personnelles, avec des autorités dédiées comme l'ANTIC et une procédure judiciaire détaillée incluant expertise et jugement. La jurisprudence locale illustre des cas clés (intrusion système, cyber-escroquerie) et souligne des défis majeurs : formation insuffisante des magistrats, délais et coûts des expertises, ainsi que l'absence de standards nationaux adaptés. Pour terminer je dirais que ce manuel comprend toute les informations nécessaires pour avec une connaissance très considérables en investigation numérique cars elle intègre des notions de la racine de l'investigation à la notion la plus récente sans délaisser les défis ainsi que les évolutions technique et judiciaire qu'on subit ses derniers.

Abstract

1